

Malicious Insider Staging Data in the Cloud response

Cloud · **Critical** severity · SOC IR Playbook

Incident type	Insider Threat - Data Staging / Exfiltration
Severity	Critical
Priority	Critical
Detection sources	DLP, CASB, SIEM, Proxy Logs, Endpoint Agents, User Reports, Insider Threat Programs

Scenario

A trusted user within the organisation abuses their access to sensitive data (e.g., PII, source code, financials) and begins uploading it to unapproved cloud platforms (e.g., personal Google Drive, Dropbox, Mega, OneDrive) for exfiltration. This may precede resignation, whistleblowing or corporate espionage.

MITRE ATT&CK

T1081, T1537, T1567.002

Preparation

Implement insider threat monitoring Use UEBA, CASB and DLP with behavioural baselines Enforce approved cloud storage policy Block unsanctioned SaaS uploads using CASB or firewall rules Monitor large file transfers and compressions Use endpoint and proxy rules to detect mass zipping or uploads Train employees on data handling policies Reinforce disciplinary and legal consequences of data misuse Use tagging for sensitive files Classify documents to apply targeted monitoring

Detection & Analysis

Alert triggered DLP or CASB detects file upload to unapproved cloud service Investigate user behaviour Look for signs of resignation, policy violations or abnormal working hours Correlate data access and transfer Identify which files were accessed, downloaded, zipped or uploaded Determine target cloud storage Personal Google Drive, Dropbox, Mega, iCloud, etc.

Containment

Block further access to external storage Enforce cloud app control through CASB or proxies Suspend or limit user account Temporarily if behaviour is clearly malicious or data loss is ongoing Isolate user device If malware or credential theft is also suspected Preserve session and file logs For forensic analysis and legal use

Eradication

Remove access to sensitive systems Revoke elevated privileges and remove from sensitive groups or shares Retrieve or delete staged data If stored on corporate device or retrievable from personal cloud (with legal support) Reset credentials and tokens Especially if user had API access or was using automation tools Disable shadow cloud accounts Prevent further access or data sync from corporate systems

Recovery

Reassign critical duties If employee was in a privileged role or part of a handover Monitor for follow-up exfiltration attempts Use enhanced logging for user accounts or similar profiles Review audit logs across systems Ensure no lateral activity or additional data transfers occurred Resume normal operations Once incident scope and risk are under control

Lessons Learned & Reporting

Conduct full insider threat RCA Understand motive, opportunity and control weaknesses Improve insider threat models Refine UEBA rules and escalation playbooks Inform HR and Legal For possible disciplinary action, legal follow-up or prosecution Review and update DLP/CASB policies Add newly abused platforms or tactics to detection

scope Notify regulators or clients If regulated data was exposed or customer confidentiality breached

Tools typically involved

DLP (e.g., Microsoft Purview, Forcepoint, Symantec DLP); CASB (e.g., Netskope, Microsoft Defender for Cloud Apps); UEBA/Insider Threat Platforms (e.g., Splunk UBA, Exabeam, Varonis); SIEM (e.g., Sentinel, Splunk); Endpoint Monitoring (e.g., CrowdStrike, Trellix, Tanium); Proxy and NGFW (e.g., Zscaler, Palo Alto); HR Systems and Legal Support Tools

Success metrics (SLA targets)

Detection Time <5 minutes from data upload Account Restriction Time <15 minutes from alert Data Recovery / Containment Time <24 hours Forensic Analysis Completion Within 48 hours Insider Threat Playbook Update Within 3 business days